

Antwort

der Bundesregierung

**auf die Kleine Anfrage der Abgeordneten Anne-Mieke Bremer, Stella Merendino, Donata Vogtschmidt, weiterer Abgeordneter und der Fraktion Die Linke
– Drucksache 21/2179 –**

Die elektronische Patientenakte – Sicherheit, Abhängigkeiten und Umsetzung des Europäischen Gesundheitsdatenraums

Vorbemerkung der Fragesteller

Die elektronische Patientenakte (ePA) und die Telematikinfrastruktur sind zentrale Bausteine der Digitalisierung des Gesundheitswesens. Mit deren Einführung gehen hohe Anforderungen an Sicherheit, Datenschutz und Verfügbarkeit einher. In den vergangenen Jahren wurden mehrfach Sicherheitslücken bekannt. Zugleich rücken Lieferkettenabhängigkeiten, geopolitische Risiken und die Rolle einzelner Unternehmen in den Fokus. Neben der zivilen elektronischen Patientenakte sind eigene Lösungen für den militärischen Bereich angekündigt, was zusätzliche Fragen nach Sicherheit, Trennung und Zuständigkeiten aufwirft. Zugleich gewinnt die Umsetzung des Europäischen Gesundheitsdatenraums (European Health Data Space – EHDS) an Bedeutung. Gegenwärtig lässt sich aus Sicht der Fragestellenden nicht eindeutig erkennen, wie weit die EHDS-Anpassungsbemühungen gediehen sind und wo noch Handlungsbedarf besteht.

1. Wie wird durch die Bundesregierung sichergestellt, dass die Lieferketten für sicherheitsrelevante Komponenten der Telematikinfrastruktur wie Konnektoren und Lesegeräte zur Authentifizierung und Identifikation von Zugriffsberechtigten auf die elektronische Patientenakte gegen Manipulationen, Ausfälle oder unautorisierte Zugriffe gesichert sind?
 - a) Aus welchen Staaten sind derzeit Unternehmen in die Herstellung, Lieferung oder Wartung dieser Komponenten eingebunden?

Die Fragen 1 und 1a werden aufgrund des Sachzusammenhangs gemeinsam beantwortet.

Der Zugriff auf die Telematikinfrastruktur (TI) erfolgt ausschließlich durch Komponenten, welche durch das Bundesamt für Sicherheit in der Informationstechnik (BSI) zertifiziert und durch die gematik zugelassen wurden. Teil der Zertifizierung ist insbesondere auch die Bewertung der sicheren Lieferketten. Die Namen der zugelassenen Komponenten (Kartenterminals, Konnektoren

und TI-Gateways) und ihre Hersteller werden durch die gematik veröffentlicht, abrufbar unter fachportal.gematik.de/zulassungs-bestaetigungsuebersichten.

- b) Welche Vorkehrungen trifft die Bundesregierung mit Blick auf zukünftige geopolitische Spannungen oder unterbrochene Handelsbeziehungen, um die Versorgungssicherheit und Integrität dieser Komponenten dauerhaft zu gewährleisten?

Das Bundesministerium für Gesundheit (BMG) und die gematik haben den Wechsel zur TI 2.0 eingeleitet, bei der die Abhängigkeit von spezifischer Hardware vermindert oder ganz aufgehoben wird. Bei den TI-Gateways ist dies bereits heute der Fall.

2. Welche kryptografischen Maßnahmen zum Schutz der Telematikinfrastruktur, insbesondere der ePA, gegen Angriffe mithilfe von Quantencomputern sind derzeit implementiert, welche sind geplant, und existiert eine umfassende Strategie der Bundesregierung zur Einführung von Post-Quanten-Kryptografie in besonders sicherheitsrelevanten Bereichen der öffentlichen IT-Infrastruktur?

Die Implementierung quantenresistenter Verfahren ist bereits erfolgt, wobei die kontinuierliche Weiterentwicklung und Anpassung an neue Bedrohungen eine dauerhafte Aufgabe bleibt. Die gematik arbeitet eng mit dem BSI zusammen, um die Sicherheitsmaßnahmen kontinuierlich zu verbessern und an neue Bedrohungslagen anzupassen.

Die gematik-Spezifikation „gemSpec_krypt“ (Verwendung kryptographischer Algorithmen in der Telematikinfrastruktur) gibt den Stand der in der TI eingesetzten kryptographischen Verfahren sowie vereinzelte Ausblicke in die weitere Verfahrensweise wieder. Die Spezifikation kann unter www.gemspec.gematik.de/docs/gemSpec/gemSpec_Krypt/ öffentlich eingesehen werden.

Im Juni 2025 wurde auf EU-Ebene ein „koordinierter Umsetzungsprojektplan für den Übergang zur Post-Quantum-Kryptographie durch die EU-Mitgliedstaaten unterstützt von der Europäischen Kommission vorgelegt, siehe unter www.digital-strategy.ec.europa.eu/en/library/coordinated-implementation-road-map-transition-post-quantum-cryptography.

Deutschland war federführend an der Erstellung dieses Projektplans beteiligt. Er enthält Empfehlungen, welche Schritte für die Umstellung auf quantensichere Kryptografie unternommen werden sollten, und insbesondere Fristen für die Umstellung. Es wird zudem die Erstellung von nationalen Projektplänen empfohlen. Entsprechend dieser Empfehlung wird zurzeit ein nationaler Projektplan zur Umstellung auf quantensichere Kryptografie erarbeitet.

3. Wie sieht nach Kenntnis der Bundesregierung die von der gematik GmbH vorgenommene Neubewertung der vom Chaos Computer Club (CCC) dargestellten Schwachstelle (www.bundesgesundheitsministerium.de/presse/pressemitteilungen/epa-sicherheitsluecke-geschlossen-pm-30-04-25.html) bei der Erstellung von Berechtigungstokens durch simulierte elektronische Gesundheitskarten aus, und inwiefern wurde eine unabhängige sicherheitstechnische Überprüfung vorgenommen?

Die Schwachstelle, die in Kombination mit der elektronischen Ersatzbescheinigung (eEB) auftrat, wurde unverzüglich geschlossen. Die eEB wird jetzt datensparsamer ausgestellt. Durch das Gesetz zur Befugnisenerweiterung und Entbürokratisierung in der Pflege, das sich derzeit im parlamentarischen Verfahren befindet (Bundestagsdrucksache 21/1511), wird erstmals auch die Möglichkeit

geschaffen, die eEB auch direkt vom Leistungserbringer per TI-Anwendung Kommunikation im Medizinwesen (KIM) an die Krankenkassen zu senden.

4. Sind sämtliche Einrichtungen und beteiligte Unternehmen vom Entwurf des NIS-2-Umsetzungsgesetzes (NIS = Netzwerk- und Informationssicherheit; Bundestagsdrucksache 21/1501) sowie vom KRITIS-Dachgesetz (KRITIS = Kritische Infrastruktur) laut Kabinettsbeschluss (www.bmi.bund.de/SharedDocs/pressemitteilungen/DE/2025/09/kritis-dg-kabinet.html) als besonders wichtige Einrichtungen bzw. als Betreiber kritischer Anlagen erfasst, die in die Telematikinfrastruktur und die ePA eingebunden sind, und wenn nein, welche Einrichtungen oder Dienstleistungen sind davon ausgenommen oder könnten davon über Öffnungsklauseln ausgenommen werden?

Die TI ist grundsätzlich vom Entwurf eines Gesetzes zur Umsetzung der NIS-2-Richtlinie und zur Regelung wesentlicher Grundzüge des Informations-sicherheitsmanagements in der Bundesverwaltung (NIS-2-Umsetzungsgesetzes) und zwar von Artikel 1, Gesetz über das Bundesamt für Sicherheit in der Informationstechnik und über die Sicherheit in der Informationstechnik von Einrichtungen (BSI-Gesetz – BSIG) erfasst. § 28 Absatz 6 BSIG regelt jedoch Ausnahmen für die gematik, für die Betreiber von Diensten der TI im Hinblick auf die nach § 311 Absatz 6 und § 325 des Fünften Buches Sozialgesetzbuch (SGB V) zugelassenen Dienste und für Betreiber von Diensten, soweit sie die TI für nach § 327 Absatz 2 bis 5 SGB V bestätigten Anwendungen nutzen. Diese Ausnahmen betreffen wesentliche Verpflichtungen besonders wichtiger Einrichtungen und wichtiger Einrichtungen und von Betreibern kritischer Anlagen. Grund für die Ausnahmeregelung ist, dass für die TI entsprechende spezialgesetzliche Regelungen im SGB V existieren.

Die TI ist grundsätzlich auch vom Entwurf eines Gesetzes zur Umsetzung der Richtlinie (EU) 2022/2557 und zur Stärkung der Resilienz kritischer Anlagen (KRITIS-Dachgesetz) erfasst. Dieses regelt im Gegensatz zum Entwurf des NIS-2-Umsetzungsgesetzes, das die IT-Sicherheit zum Gegenstand hat, den physischen Schutz kritischer Infrastrukturen. Da der physische Schutz informationstechnischer Einrichtungen grundsätzlich bereits bei den IT-Sicherheitsmaßnahmen zu berücksichtigen ist, hat das KRITIS-Dachgesetz lediglich geringe Auswirkungen auf die TI.

5. Hat das Bundesministerium für Gesundheit zur sicherheitspolitischen Bewertung der Vergabe und technischen Umsetzung der ePA die sicherheitsrelevante Expertise der zuständigen Bundesinstitutionen eingeholt, insbesondere des Bundesamts für Sicherheit in der Informationstechnik (BSI), des Bundesnachrichtendienstes (BND), des Militärischen Abschirmdienstes (MAD), des Bundesamts für Verfassungsschutz (BfV), des Bundeskriminalamts (BKA), der Zentralen Stelle für Informationstechnik im Sicherheitsbereich (ZITiS), des Cyber-Abwehrzentrums sowie des Bundesministeriums des Innern (BMI), und wenn ja, wann und in welcher Form wurden diese Stellen jeweils einbezogen und mit welchen Ergebnissen?

Die zuständige Bundesinstitution für Fragen der Sicherheit der TI ist das BSI, sodass nur dieses zu beteiligen war.

6. Sind für Angehörige sicherheitsrelevanter Berufsgruppen und Geheimnisträgerinnen und Geheimnisträger besondere Schutzmaßnahmen geplant im Rahmen der ePA, um die erhöhte Schutzbedürftigkeit ihrer Gesundheitsdaten zu berücksichtigen?

Die im Rahmen der Spezifikation und Implementierung der elektronischen Patientenakte (ePA) vorgenommenen Datenschutz- und Datensicherheitsmaßnahmen für medizinische Daten sind grundsätzlich für alle Personengruppen sehr hoch. Weiterhin wurde ein technischer und organisatorischer Betreiberausschluss umgesetzt. Zudem ist die Nutzung der ePA freiwillig (Opt Out). Darüber hinaus sind für Angehörige sicherheitsrelevanter Berufsgruppen und Geheimnisträgerinnen und Geheimnisträger keine besonderen darüber hinausgehenden Schutzmaßnahmen vorgesehen.

7. Aus welchen Gründen plant die Bundeswehr, eine eigenständige ePA zu entwickeln bzw. einzusetzen, statt die bestehende zivile ePA-Infrastruktur zu nutzen, und welche sicherheitstechnischen, organisatorischen oder rechtlichen Erwägungen stehen einer gemeinsamen Nutzung entgegen?
 - a) Wird derzeit geprüft, eine technisch abgeschottete Spezialanwendung auf Basis der zivilen ePA in Auftrag zu geben?
 - b) Soll die ePA der Bundeswehr vollständig getrennt von der zivilen Telematikinfrastruktur betrieben werden?

Die Fragen 7 bis 7b werden aufgrund des Sachzusammenhangs gemeinsam beantwortet.

Die Bundeswehr plant keine eigenständige ePA und wird auf marktverfügbare, durch die gematik zugelassene Produkte zurückgreifen.

- c) Welche Bundesbehörden, sicherheitsrelevanten Stellen und welche Unternehmen sind in die Konzeption und sicherheitstechnische Prüfung der ePA für die Bundeswehr eingebunden?

Die gematik nimmt alle im Sinne der Fragestellung aufgeführten Aufgaben für die Bundeswehr wahr.

- d) Welche besonderen sicherheitstechnischen Anforderungen gelten für die ePA der Bundeswehr im Vergleich zur zivilen ePA, und inwiefern unterscheiden sich Architektur, Zugriffskontrolle, Datenhaltung und Verschlüsselungstechnologien im militärischen Kontext?

Es gelten die gleichen sicherheitsrelevanten Anforderungen für beide Systeme.

- e) Wird es eine Widerspruchsmöglichkeit geben?

Ja, es wird eine Widerspruchsmöglichkeit geben.

8. Wurde bei der Entwicklung und Programmierung der ePA ein Threat-Modell zur systematischen Bedrohungsanalyse eingesetzt, wenn ja, welches Modell wurde verwendet und aus welchen Gründen, und wenn nein, aus welchen Erwägungen wurde darauf verzichtet?

Im Rahmen der ePA-Spezifikation wurde eine systematische Bedrohungsanalyse durchgeführt. Diese Analyse folgt anerkannten besten Praktiken und wurde mit dem BSI und der Bundesbeauftragten für den Datenschutz und die Informationsfreiheit (BfDI) abgestimmt.

9. Wurde im Rahmen der Entwicklung der ePA ein Architecture Decision Record geführt, um zentrale Architekturentscheidungen nachvollziehbar zu dokumentieren, und wenn ja, ist dieser öffentlich einsehbar bzw. wird eine Offenlegung gegenüber dem Parlament geprüft?

Architekturentscheidungen die TI im Allgemeinen und die ePA im Speziellen betreffend werden durch die gematik in Abstimmung mit den Gesellschaftern der gematik sowie dem BSI und der BfDI getroffen und entsprechend intern dokumentiert. Öffentlich einsehbar sind die Ergebnisse dieser Entscheidungen in Form von Fachkonzepten und Spezifikationen.

10. Welchen Zeitplan verfolgt die Bundesregierung bezüglich der Umsetzung der Verordnung über den Europäischen Gesundheitsdatenraum (EHDS-Verordnung)?
 - a) Welcher Anpassungsbedarf ergibt sich aus Sicht der Bundesregierung bezogen auf die ePA und ihre rechtlichen Grundlagen aus der EHDS-Verordnung (soweit dies noch Gegenstand von Prüfungen ist, auf welche Aspekte beziehen sich diese Prüfungen, und bis wann plant die Bundesregierung, sie abzuschließen)?

Die Fragen 10 und 10a werden aufgrund des Sachzusammenhangs gemeinsam beantwortet.

Das BMG prüft derzeit, welche rechtlichen Anpassungsbedarfe sich bezogen auf die ePA aus der EHDS-Verordnung ergeben. Die Prüfung bezieht sich insbesondere auf Aspekte der Zugangs- und Zugriffsverwaltung. Die Prüfung wird stetig fortgeführt, um erforderliche Anpassungen bis zum Anwendungsbeginn der entsprechenden Regelungen der EHDS-Verordnung zeitgerecht umsetzen zu können.

- b) Hat die Bundesregierung Kenntnis von aus Sicht der Fragestellenden möglichen Überlegungen, den EHDS mit der EU-Digital Identity Wallet nach der eIDAS-Verordnung (eIDAS: Electronic Identification, Authentication and Trust Services) zu verknüpfen, und hat sich die Bundesregierung eine Auffassung dazu gebildet, wie sie eine mögliche Verknüpfung bewerten würde?

Die Bundesregierung prüft, wie in der Fortentwicklung der Nutzung digitaler Identitäten im Gesundheitswesen allgemein sowie mit Bezug zur Umsetzung der EHDS-Verordnung Synergien zur Umsetzung der neugefassten eIDAS-Verordnung gehoben werden können und technologische Konvergenz erreicht werden kann. Ebenso prüft die Bundesregierung, welche Verpflichtungen bestehen, die Nutzung von persönlichen digitalen Brieftaschen (Digital Identity Wallets) nach der eIDAS-Verordnung im Kontext der Umsetzung der EHDS-Verordnung zu ermöglichen. Dabei wird berücksichtigt, dass Patientinnen und Patienten in ihrer Gesundheitsversorgung nicht schlechter gestellt werden dürfen, wenn sie keine persönliche digitale Brieftasche nach der eIDAS-Verordnung nutzen können oder wollen.

- c) Welche Ausnahmen vom Opt-Out zur Sekundärnutzung im Rahmen des EHDS sind der Bundesregierung bekannt, wie bewertet sie deren Reichweite, und wie definiert sie diese Ausnahmen?

Auf die Antwort zu Frage 10a wird verwiesen. Ob Ausnahmen vom Recht zum Widerspruch gemäß Artikel 71 Absatz 4 EHDS-Verordnung in Betracht kommen, wird die Bundesregierung prüfen.

11. Welche Verträge über welche Dienstleistungen und in welchem finanziellen Umfang wurden zu welchen Daten zwischen der „Gematik“ und der „Arvato Systems“ geschlossen?

Hierbei handelt es sich um Geschäftsgeheimnisse, zu denen die Bundesregierung keine Auskunft geben kann.

- a) Welche Maßnahmen der Qualitätssicherung ergreift die „Gematik“ in Bezug auf die von der „Arvato Systems“ übernommenen Leistungen?

Die gematik überprüft regelmäßig anhand vertraglich festgelegter Kriterien die erbrachten Leistungen. Die übergreifende Spezifikation „Performance und Mengengerüst TI-Plattform“ wird durch die gematik veröffentlicht, abrufbar unter gemspc.gematik.de/docs/gemSpec/gemSpec_Perf/latest/.

- b) Welche Störungen der Telematikinfrastruktur gab es seit ihrer Einführung, welche Gründe hatten die Störungen, und wurden sie so behoben, dass sie in dieser Form nicht wieder auftreten können?

Die Störungsursachen sind von Fall zu Fall unterschiedlich. Grundsätzlich gilt: Störungen in der TI entstehen häufig durch Beeinträchtigungen von einzelnen Komponenten oder Diensten, die von unterschiedlichen Herstellern betrieben werden. Diese Anbieter unterliegen strengen regulatorischen Vorgaben – etwa hinsichtlich Verfügbarkeit, Reaktions- und Lösungszeiten sowie Dokumentationspflichten bei Störungen. In der Regel können Störungen durch den jeweiligen Dienstleister oder Hersteller meist zügig behoben werden.

In der TI wirken viele Beteiligte und Komponenten miteinander: Dieses Gesamtgefüge begleitet die gematik eng und steht in kontinuierlichem Austausch mit Herstellern, Anbietern und Dienstleistern. Im Störfall erfolgt umgehend die Ursachenanalyse.

Eine Übersicht über TI-Beeinträchtigungen der letzten 14 Tage bietet die gematik in ihrem Fachportal an: www.fachportal.gematik.de/ti-status.

- c) Wurden weitere Unternehmen von der „Gematik“ mit Leistungen zur Telematikinfrastruktur beauftragt, und wenn ja, welche Unternehmen, welche Verträge und welches Auftragsvolumen liegen jeweils vor?

Die gematik ist die offizielle Zulassungsstelle für sämtliche TI-Produkte sowie für Anbieter operativer Betriebsleistungen und weiterer Anwendungen. Sie veröffentlicht alle Zulassungen und Bestätigungen unter www.fachportal.gematik.de/zulassungs-bestaetigunguebersichten.

